Tietoturva ja tietosuoja

Tietokannan varmistaminen ja suojaaminen

Oppimistavoitteet

1. Opitaan tietokannan varmistuksen tekniikoita ja käytäntöjä.
2. Ymmärretään tietoturvan ja tietosuojan vaatimukset ja toteutustavat tietokantojen yhteydessä.
3. Hahmotellaan tuotantokäytössä olevan tietokannan muutosten toteutustapaa.

Ongelmien ennaltaehkäisy

- Tietokannan tuhoutumista ja korruptoitumista voidaan estää monilla tavoilla:
  - Laadukas datan mallinnus eheysrajoitteineen
  - Levyjen vikaantumiseen varautuminen
    - Redundanssin luominen RAID-järjestelmällä.
    - Mahdollista toteuttaa ratkaisu, jossa yksi vikaantunut levy voidaan korvata uudella lennosta ilman, että palvelimen toimintaan aiheutuu katkoa.
  - Loggaus (esim. MariaDB:n kyselyloki ja virheloki) voivat helpottaa vikatilanteista toipumista.
  - Varmuuskopiointi.
  - Tietokantaan kohdistuvien päivitysten huolellinen suunnittelu.

Varmuuskopioinnin tavoitteet

- Varmuuskopioita voi hyödyntää moneen tarkoitukseen:
  - Poikkeustilanteista toipuminen
    - viat
    - katastrofit
  - Datan palautus
  - Kehitysympäristön kopiointi tuotantoympäristöstä
  - Tietokannan hajauttaminen
    - Luodaan tietokannasta kopioita eri palvelimille
    - Isäntä-orja-arkkitehtuuri
      - Päivitykset isäntäkoneelle, josta ne kopioituvat orjakoneille

Varmuuskopiointistrategia

- Varmuuskopiointi on syytä suunnitella ja organisoida.
- Kysymyksiä, joihin on haettava vastaus:
  - Kauanko varmuuskopiointi saa kestää?
  - Kuinka pitkään järjestelmä saa olla pois käytöstä poikkeustilanteen aikana?
  - Saako järjestelmä olla poissa käytöstä varmuuskopioinnin aikana?
  - Saako dataa tuhoutua poikkeustilanteessa?
  - Kuinka nopeasti tietokanta on pystyttävä palauttamaan?
  - Kuinka dynaamista data on (INSERT/UPDATE/DELETE-tiheys)?
  - Kauanko varmuuskopioita on säilytettävä, ja missä niitä pitää säilyttää (mahdolliset lainsäädännölliset vaatiumkset)?
- Tuloksena voi olla kustannukseltaan hyvin erilainen varmuuskopiointistrategia.
- Katsotaan seuraavaksi erilaisia tapoja luokitella varmuuskopioita.

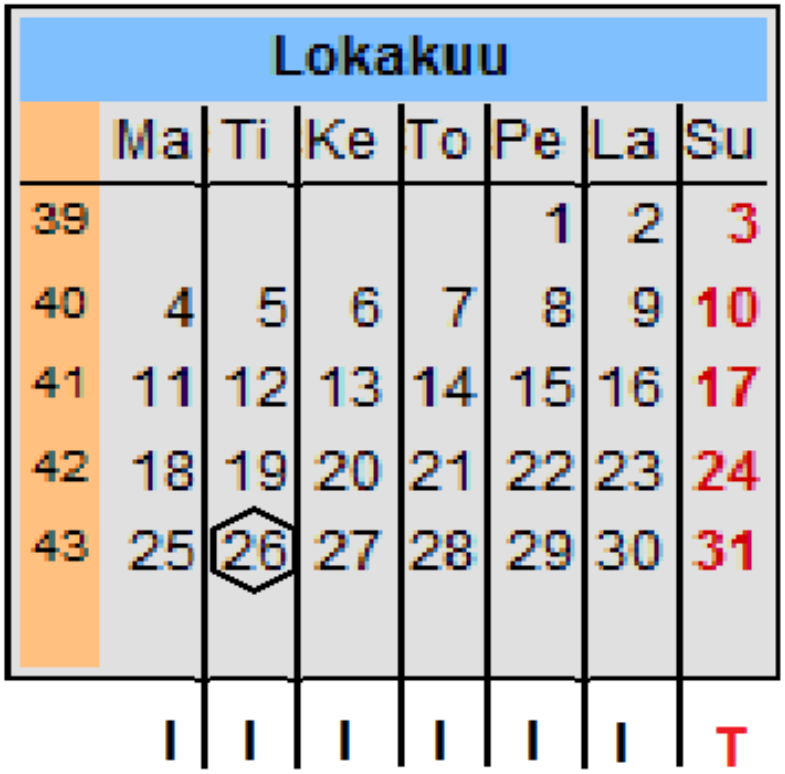
Täysi ja inkrementaalinen varmuuskopio

A. Täysi varmuuskopio
   - Täydellinen kopio tietokantapalvelimen datasta ja metadatasta.
   - Mahdollistaa palvelimen replikoimisen.

B. Inkrementaalinen varmuuskopio
   - Kopioidaan vain data, joka on muuttunut viimeisen täyden tai inkrementaalisen varmuuskopion jälkeen.
   - Vaatii tuekseen ajoittaiset täydet varmuuskopiot.

Esimerkki: inkrementaalinen varmuuskopiointi

- Esimerkki: täysi varmuuskopio tehdään sunnuntaisin ja inkrementaalinen muina viikonpäivinä.
- Katastrofi tapahtuu tiistaina 26.10.
- Toipuminen:
  1. Aluksi palautetaan tietokanta su 24.10. täydestä varmuuskopiosta.
  2. Seuraavaksi päästään ma 25.10. tilanteeseen tuon päivän inkrementaalisesta varmuuskopiosta.
  3. Lopuksi palautetaan ti 26.10. tilanne kyseisen päivän inkrementaalisesta varmuuskopiosta.
  4. Palautusta jatketaan lokin perusteella varmuuskopiointihetkestä lukien, jos sellainen on saatavilla.



Tietokannan käyttö varmuuskopioinnin aikana

A. Kylmä varmuuskopio
   - Tietokanta on poissa käytöstä varmuuskopioinnin ajan.
   - Varmuuskopio on sisäisesti ristiriidaton.

B. Lämmin varmuuskopio
   - Tietokantaan sallitaan luku- mutta ei kirjoitusoperaatioita varmuuskopioinnin aikana.
   - Varmuuskopio on nytkin sisäisesti ristiriidaton.

C. Kuuma varmuuskopio
   - Varmuuskopiointi tehdään tietokannan ollessa käytössä.
   - Varmuuskopio voi olla sisäisesti ristiriitainen, jos osa datasta on muuttunut sen aikana.
     - Esim. Oracle kirjaa lokiin varmuuskopioinnin aikana tapahtuneet operaatiot (ns. *redo log*), jotta palautus onnistuu.
   - Varmuuskopiointi saattaa hidastaa tietokannan käyttöä levyoperaatioiden vuoksi.

Looginen ja fyysinen varmuuskopio

A. Looginen varmuuskopio
   - Varmuuskopio perustuu tietokannan rakenteesta ja datasta tuotettuun SQL-esitykseen.
     - CREATE TABLE, INSERT, ...

B. Fyysinen varmuuskopio
   - Varmuuskopioinnin kohteena ovat suoraan levyllä olevat fyysiset tiedostot.

MariaDB: looginen varmuuskopio

```
[root@olliv-001 ~]# mysqldump -p firma > varmuuskopio.sql
```

- Looginen varmuuskopio voidaan ottaa MariaDB:n mukana tulevalla **`mysqldump`**-komennolla.
- Komento tuottaa tietokantaskriptin, jonka avulla voidaan palauttaa tietokannan metadata ja data
  - **`CREATE TABLE`** -lauseet
  - **`CREATE INDEX`** / **`VIEW`** / **`PROCEDURE`** -lauseet jne.
  - **`INSERT`**-lauseet
- Linux-ympäristössä komennon voi esimerkiksi upottaa osaksi **`bash`**-skriptiä ja sen voi antaa ajastetusti **`cron`**-demonin suoritettavaksi.
  - Suoritettavia komentoja voi hallinnoida **`crontab`**-komennolla.

MariaDB: fyysinen varmuuskopio

- MariaDB:ssä tiedostot ovat oletusarvoisesti kansiossa **`/var/lib/mysql`**.
  - MariaDB:n InnoDB-tietokantamoottori käyttää kahdenlaisia tiedostoja:
    - **`ibdata1`**-tiedosto datalle, indekseille jne.
      - Se on pilkottavissa taulukkokohtaisiin tiedostoihin järjestelmämuuttujan arvoa vaihtamalla (**`innodb_file_per_table`**-muuttuja)
    - **`.frm`**: skeematiedostot (relaatiokaavion esitys)
  - Vastaavasti MyISAM-tietokantamoottori käyttää kolmenlaisia tiedostoja:
    - **`.myd`**: datatiedostot
    - **`.myi`**: indeksitiedostot
    - **`.frm`**: skeematiedostot (relaatiokaavion esitys)
- Käytännössä fyysinen varmuuskopio kannattaa tehdä apuohjelmilla.
  - Linux-ympäristössä esimerkiksi **`cron`**-ajastetut **`bash`**-skriptit.

Tietokannan turvallisuus

- Tietokannan turvallisuus koostuu kolmesta osatekijästä:
  1. Luottamuksellisuus
     - Tietokannassa olevaan dataan pääsevät käsiksi vain sellaiset henkilöt, joilla on siihen oikeus.
  2. Eheys
     - Tietokannassa oleva data on suojattu asiattomalta muuntamiselta ja muuntumiselta.
  3. Käytettävyys
     - Tietokannassa oleva data on asianomaisten käyttäjien saatavilla.
- Nämä vastaavat yleisiä tietoturvan osatekijöitä.
- Tietokannan turvallisuuden vaarantuminen voi pahimmillaan johtaa tuntuviin inhimillisiin ja taloudellisiin haittoihin.
- Käyttäjätilien ja käyttöoikeuksien määritys on keskeinen tietokannan turvallisuustekijä.

Käyttäjätilit

- Tuotantokäytössä olevalla tietokannalla on syytä olla nimetty ylläpitäjä.
- Tietokannan ylläpitäjä (*Database administrator*, *DBA*) on henkilö, joka
  - luo käyttäjätilejä
  - myöntää ja poistaa käyttöoikeuksia
  - määrittää kuhunkin käyttäjätiliin liittyvät turva-asetukset.
- Käyttäjä voi olla
  - henkilö (admin-käyttäjätilit)
  - sovellus

Käyttöoikeuksien hallinta

- Esimerkiksi MariaDB tukee vapaamääritteistä käyttöoikeuskäytäntöä.
- Tapahtuu SQL-kielen avulla:
  - GRANT myöntää oikeuden.
  - REVOKE poistaa oikeuden.
- Säädettävissä eri tasoisille tietoalkioille
  - Tietokannat
  - Taulukot
  - Kentät
  - Näkymät
- Periaate: annetaan pienimmät tarvittavat oikeudet.
- MariaDB-ympäristössä oikeudet ovat **`mysql`**-nimisessä tietokannassa.

Esimerkkejä oikeustasojen määrityksestä

- Globaali

```
GRANT SELECT, INSERT, UPDATE,
DELETE ON *.* TO
'dataminer'@'localhost';
```

- Tietokantatason

```
GRANT SELECT, INSERT, UPDATE,
DELETE ON Kauppa.* TO
'webstore'@'10.80.84.12';
```

- Taulutason

```
GRANT ALL ON Firma.ASIAKAS TO
'teuvo'@'10.80.%';
```

- Kenttätason

```
GRANT SELECT (Etunimi,
Sukunimi) ON Firma.ASIAKAS TO
'maisa'@'154.12.86.1';
```

Käyttäjätileistä

- Pääkäyttäjän käyttöoikeus (**`root`**) rajataan palvelimen ylläpitotarkoituksiin.
- Tietokantaa käyttävälle sovellukselle (esim. Apache-palvelimella olevalle verkkokauppaohjelmalle) annetaan yksi rajattu käyttäjätunnus.
  - Tyypillisesti **`SELECT`**, **`INSERT`**, **`UPDATE`**, **`DELETE`** yhteen tietokantaan.
  - Mahdollista rajata vielä tarkemmin esimerkiksi estämällä poisto-operaatiot tuotetauluun.

Muita käyttöoikeuksien määritystapoja

- Pakottava käyttöoikeuskäytäntö (*Mandatory access control*, MAC)
  - Käytössä korkean turvatason järjestelmissä.
  - Käyttöoikeuksia ylläpidetään keskitetysti eikä niitä voi ohittaa.
  - Tietoalkiot luokitellaan turvaluokkiin, samoin käyttäjät.
  - Tietoalkioita joudutaan duplikoimaan eri turvaluokkia varten.
  - Esim. Oracle Label Security
- Roolipohjainen käyttöoikeuskäytäntö (*Role-based access control*, RBAC)
  - Kullekin roolille annetaan käyttöoikeudet.
  - Kukin käyttäjä liitetään yhteen tai useampaan rooliin.
  - Roolit voivat olla aikaan sidottuja.

MariaDB: tietoturvaseikkoja

- Tietoliikenteen salaaminen käyttäjän ja palvelimen välillä.
  - TLS-yhteyskäytännön käyttöönotto.
  - Voit tarkistaa tilan järjestelmämuuttujasta have_ssl.
  - Käynnistä **`mysqld`** valitsimella **`--ssl`**.
- **`mysqld`**-palvelimen ajo tavallisin oikeuksin.
  - Ei Linuxin **`root`**-pääkäyttäjänä
- Tiedon tallentaminen salatussa muodossa.
  - Edellyttää liitännäisen käyttöönottoa.
- Turvakäytännöt asennuksessa (**`mysql_secure_installation`** -skripti)
  - **`root`**-salasanan asetus
  - **`root`**-tunnuksen esto **`localhost`**-domainin ulkopuolelta
  - Anonyymitunnusten poisto
  - Testitietokannan poisto
- Palomuurin asetus: suojataan MariaDB-portti 3306 siten, että vain halutuista IP-osoitteista tuleviin yhteydenottoihin vastataan.
  - Tämä siis tietokannan käyttäjätunnuksiin liittyvien IP-määritysten lisäksi.

Lähde: MariaDB-dokumentaatio

Tietosuoja ja henkilötiedot

- Henkilötietojen käsittely tietokannassa asettaa velvoitteita, mm.:
  - Henkilötietojen suojaus- ja huolellisuusvelvoite
  - Käyttötarkoitussidonnaisuus
  - Tietojen minimointi ja säilytyksen rajoittaminen
  - Rekisteröidyn oikeuksien (tietojen tarkistus-, oikaisu-, poisto- ja siirrettävyysoikeus) toteutusvelvoite
  - Arkaluontoisten tietojen käsittelykielto
  - Rajoituksia datan siirrossa EU:n ulkopuolelle
  - Tietomurtoilmoitusvelvoite
- Lainsäädäntö:
  - EU:n tietosuoja-asetus (GDPR) vuodesta 2018
  - Laki henkilötietojen käsittelystä (tietosuojalaki, 1050/2018)

Roolit ja vastuut

- Rekisterinpitäjä
  - Organisaatio tai taho, joka määrittelee henkilötietojen käsittelyn tarkoitukset ja keinot.
- Tietosuojavastaava
  - Henkilö, joka neuvoo ja valvoo sitä, että organisaatio noudattaa tietosuojalainsäädäntöä.
  - Toimii yhteyshenkilönä viranomaisiin ja rekisteröityihin päin.
- Tietokannan ylläpitäjä (DBA)
  - Henkilö, joka vastaa tietokannan teknisestä toimivuudesta ja ylläpidosta.
- Henkilötietojen käsittelijä
  - Toimija (esim. palveluntarjoaja), joka käsittelee henkilötietoja rekisterinpitäjän puolesta ja ohjeiden mukaan.

Case: Psykoterapiakeskus Vastaamo

Laiminlyöntejä potilastietojen turvallisen käsittelyn perustoimenpiteissä

Nixun teknisen tutkinnan mukaan Vastaamon potilastietojärjestelmän palvelimen ylläpidossa ei noudatettu turvallisen palvelun ylläpidon parhaita käytäntöjä ja suojausmenetelmiä, mikä on altistanut palvelimen verkkohyökkäyksille.

Todennäköisin syy potilastietokannan vuodolle on ollut tietokannan suojaamaton MySQL-portti, jossa tietokannan root-pääkäyttäjätunnusta ei ollut suojattu salasanalla. Käyttäjätunnukselle oli myös annettu oikeus kirjautua tietokantaan mistä tahansa IP-osoitteesta. Potilastietokannan palvelin on ollut ilman palomuurisuojausta auki internetiin vähintään 26.11.2017 ja 13.3.2019 välisen ajan.

Apulaistietosuojavaltuutettu katsoo, että henkilötietoja ei ollut asianmukaisesti suojattu luvattomalta ja lainvastaiselta käsittelyltä tai vahingossa tapahtuvalta häviämiseltä, tuhoutumiselta tai vahingoittumiselta, eikä Vastaamo ollut toteuttanut henkilötietojen turvallisen käsittelyn perustoimenpiteitä. Puutteellisen dokumentaation vuoksi Vastaamo ei myöskään pystynyt osoittamaan, että se olisi noudattanut asianmukaista turvallisuutta koskevia vaatimuksia.

Lähde: Tietosuojavaltuutetun toimiston tiedote 16.12.2021. https://tietosuoja.fi/-/psykoterapiakeskus-vastaamolle-seuraamusmaksu-tietosuojarikkomuksista.

Skeemamuutokset tuotannossa olevaan tietokantaan

- Ryhdy muutoksiin vain tarpeesta. Suunnittele prosessi ja sen ajoitus huolella.
  - Valitse hiljaisen kuormituksen ajankohta.
  - Aseta tarvittaessa käyttökatko ja tiedota siitä etukäteen.
- Ota tuotantokannasta kopio kehitysympäristöön.
- Kirjoita ja testaa migraatioskripti (esim. ALTER TABLE- ym. lauseet) kehitysympäristössä.
  - Muista versionhallinta: yleensä luontiskripti ja inkrementaaliset migraatioskriptit
- Määrittele palautusprosessi mahdollisia ongelmatilanteita varten. Toteuta ja testaa prosessi tarvittaessa.
- Ota varmuuskopio tuotantokannasta ennen muutosta.
- Aja testattu päivitysskripti tuotantoon, tarkista onnistuminen ja seuraa vaikutuksia.